

Festo Smart Factory Lab - Final Assignment

Aleksander Kłap - Lourdes Gaurisse

June 22, 2026

Contents

1	Introduction and Scope	1
2	Description of the System	2
2.1	Asset Inventory	2
3	As-Is Architecture	5
3.1	Communications Mapping	5
3.2	Trust Zones and Segmentation	5
3.3	Network Identification	7
4	Threat and Risk Analysis	10
4.1	Threat Modelling	10
4.2	Threat Scenarios	10
4.3	Threat Table	11
4.4	Risk Matrix	11
5	Security Requirements	12
6	To-Be Architecture	16
6.1	Logical Network Redesign	16
6.2	Logic Zones	17
6.3	New Nodes	17
6.4	Firewalls	18
6.5	Network Implementation	18
7	Hardware	21
7.1	Protocol Hardening	21
7.2	Security Hardware	22
8	Standards and Regulatory Alignment	24
9	Discussions and Limitations	25
9.1	Organizational & Procedural Measures	25
10	Conclusion	26

List of Tables

10	Assessment Scope Key Findings	5
11	IEC 62443 Violations	6
12	ISO/IEC 27001 Violations	6
13	NIS2 Directive Violations	6
14	Defense-in-Depth Violations	7
15	Least Privilege & Zero Trust Violations	7
16	OT Network Devices	8
17	IT / MES Network Devices	8
18	ICS Threat Analysis Matrix (IEC 62443-based)	11
19	ICS Threat Risk Assessment	11
20	Security Requirements Overview	24

List of Figures

1	Zone & Conduit Diagram	16
2	Network Implementation	19

1 Introduction and Scope

This report presents a comprehensive security assessment of the FESTO Smart Factory, covering its current architecture, the threats and risks it faces, and a set of concrete mitigation measures. The analysis is grounded in a detailed inventory of the factory’s hardware, software, and communication protocols, established through physical inspection of the installation, network traffic capture, and review of vendor and protocol documentation.

The scope of this report is limited to the security posture of the factory as observed during the assessment period; it does not extend to physical safety systems, production quality assurance, or components outside the network boundary defined in Section 3. Findings are evaluated against recognised industrial security standards, and the proposed mitigations are scoped to be realistically implementable within the lab environment.

2 Description of the System

2.1 Asset Inventory

Network Infrastructure

Asset	Model	IP	MAC	Protocols	Function
MES PC	SIMATIC-PC	172.21.0.90	4c:d7:17:90:73:a2	OPC UA, NTP, HTTP, HTTPS	MES, MES database, NTP server
MQTT device	Festo	172.21.0.210	00:0E:F0:7C:A3:C0	MQTT	MQTT device publishing telemetry data to MES
Router	TP-Link router	172.21.0.200	20:23:51:41:a2:88	UDP	Router

Station 0 — Robot Arm Station (172.21.1.x/18)

Asset	Model	IP	MAC	Protocols	Function
Switch S0	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 0 network distribution
PLC - TODO					
HMI - TODO					
Robot Arm Controller	UR3e	TODO ip	TODO mac	UR Bus / Ethernet	Pick & place robot arm control
RFID Reader	Turck TBEN-S2-2RFID-4DXP	172.21.1.20	00:07:46:aa:07:cc	PROFINET	RFID identification of transport trays

Station 1 — Conveyor Belt (172.21.1.x)

Asset	Model	IP	MAC	Protocols	Function
Switch S1	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 1 distribution
HMI S1	Siemens MTP700 Unified Comfort	172.21.1.10	30:13:89:35:da:a8	PROFINET	Operator panel (confirm ownership)
PLC S1	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.1.1	30:B8:51:32:D3:E7	PROFINET, HTTP, OPC-UA, S7comm	Process control S1
PC Cobot-ML	unknown	172.21.1.90	08:bf:b8:f1:25:e3	OPC-UA, HTTP	Image Processing

Station 2 — Ball Sorting / Dispense (172.21.2.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S2	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 2 distribution
PLC S2	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.2.1	30:b8:51:33:7e:c7	PROFINET, HTTP, OPC-UA, S7comm	Process control S2
HMI S2	Siemens MTP700 Unified Comfort	172.21.2.10	30:13:89:35:d8:af	PROFINET, S7comm+, NTP	Operator panel
FESTO Controller - TODO					
Power Monitor S2	Siemens	172.21.2.61	10:DF:FC:17:DC:72	TODO	Power consumption monitoring

Asset	Model / Firmware	IP	MAC	Protocols	Function
IO Device	Siemens ET200SP IM155-6PN/2 HF / V4.2.4	172.21.2.100	4c:e7:05:4b:46:4b	PROFINET IO	Remote IO module - ball dispenser control

Station 3 — Camera Inspection (172.21.3.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S3	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 3 distribution
PLC S3	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.3.1	30:b8:51:32:d3:9b	PROFINET, HTTP, OPC-UA, S7comm	Process control S3
HMI S3	Siemens MTP700 Unified Comfort	172.21.3.10	30:13:89:2c:e9:c5	PROFINET	Operator panel
Camera	SensoPart	172.21.3.50	00:19:6F:0D:A3:72	HTTP	Monitoring ball distribution on tray

Station 4 — Magazine (172.21.4.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S4	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 4 distribution
PLC S4	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.4.1	30:b8:51:33:7e:24	PROFINET, HTTP, OPC-UA, S7comm	Process control S4
HMI S4	Siemens MTP700 Unified Comfort	172.21.4.10	30:13:89:35:D9:EF	PROFINET	Operator panel
CPX Terminal	Festo CPX (197330)	TODO	TODO	TODO	Agreggate Festo Controllers monitoring data

Station 5 — Muscle Press (172.21.5.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S5	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 5 distribution
PLC S5	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.5.1	30:b8:51:33:7e:62	PROFINET, HTTP, OPC-UA, S7comm	Process control S5
HMI S5	Siemens MTP700 Unified Comfort	172.21.5.10	30:13:89:36:6A:EE	PROFINET	Operator panel

Station 6 — Oven (172.21.6.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
HMI S6	Siemens MTP700 Unified Comfort	172.21.6.10	30:13:89:35:d9:c7	PROFINET	Operator panel
Switch S6	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 6 distribution
PLC S6	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.6.1	30:B8:51:32:D4:5F	PROFINET, HTTP, OPC-UA, S7comm	Process control S6
FESTO Controller - TODO					
Power Monitor S6	TODO	172.21.6.61	10:DF:FC:17:DC:6C	TODO	Power consumption monitoring

3 As-Is Architecture

3.1 Communications Mapping

Source	Destination	Protocol/Port	Direction	Purpose
MES	PLC	OPC-UA / 4840	MES (client) → PLC (server)	Read/write process data
HMI / PLC	MES	NTP / 123	Clients → NTP server	Time sync
Internet	MES	HTTPS / 443	Internet → MES	Webshop orders
Cobot-ML PC	Camera	HTTP / 80	Cobot-ML → Camera	Fetch inspection image
Cobot-ML PC	PLC	OPC-UA / 4840	Cobot-ML → PLC	Process data from image
PLC	IO Device	PROFINET (L2)	PLC → IO	Cyclic I/O exchange
Festo Ctrl	CPX-IoT (CVX)	MQTT / 1883	Ctrl → CVX	Publish aggregated data
RFID Reader	PLC	PROFINET (L2)	Reader → PLC	RFID identification
PLC	Robot Arm	PROFINET (L2)	PLC → Robot	Motion commands / status
HMI	PLC	S7comm+ / 102	HMI → PLC	Read/write panel tags
MES PC	PLC	S7comm+ / 102	MES → PLC	PLC programming
MES PC	HMI	S7comm+ / 102	MES → HMI	HMI programming/config
Power Monitor	Festo Ctrl	Modbus / 502	Monitor → Ctrl	Power consumption data

3.2 Trust Zones and Segmentation

This assessment evaluates the security posture of the Festo Smart Factory Lab OT/ICS network. The lab comprises six manufacturing stations (conveyor, sorting, camera inspection, magazine, press, oven) plus a robot arm cell, interconnected through Siemens S7-1500 PLCs, Festo CPX controllers, MTP700 HMIs, and a centralised MES PC.

The assessment is based on passive packet capture analysis (5 captures, 55,000 frames), active DCP Identify-All output (14 devices), and nmap host discovery (21 live hosts across 172.21.0.0/18).

Assessment Scope	Key Finding
Network segmentation	NONE — fully flat /18 subnet
PLC access control	NONE — all PLCs reachable from any host
MES / OT separation	NONE — MES PC shares subnet with PLCs
Engineering access control	NONE — uncontrolled, incl. unregistered devices
Unaccounted assets	6+ devices not in original inventory
Wireless / external exposure	TP-Link AP present on OT subnet

Table 10: Assessment Scope Key Findings

The overall security posture is assessed as **CRITICAL**. The network presents no meaningful barrier between IT systems, engineering workstations, visitor devices, and live industrial control equipment. A single compromised host on the subnet has unrestricted access to all PLCs and HMIs.

Regulatory and Standards Alignment

Security Issue Found	Standard Violated
No zones or conduits — entire network is one implicit zone with no conduit controls	IEC 62443-1-1 (Zone & Conduit Model)
Incomplete asset inventory (6+ undocumented devices during active operation)	IEC 62443-2-1 (CSMS — Asset Inventory)
No authentication on PLC web servers or PROFINET	IEC 62443-3-3 / SR 1.1 (Human User Identification & Authentication)
No controlled access path for remote engineering	IEC 62443-3-3 / SR 2.6 (Remote Session Termination)
No network segmentation or zone boundary protection	IEC 62443-3-3 / SR 5.1 & SR 5.2 (Network Segmentation & Zone Boundary Protection)

Table 11: IEC 62443 Violations

IEC 62443 Violations

Security Issue Found	Standard Violated
Six devices absent from inventory, including one actively programming PLCs via S7comm (172.21.0.156)	Clause 8.1 / Annex A.8 (Asset Management)
Flat /18 subnet with no separation between services, users, or systems	Annex A.8.22 (Network Segmentation)
No firewall, ACL, or VLAN between MES-level and field-level devices	Annex A.8.20 (Network Security)

Table 12: ISO/IEC 27001 Violations

ISO/IEC 27001 Violations

Security Issue Found	Standard Violated
No network segmentation, access control, or asset management in lab network	Article 21 — Cybersecurity Risk Management
Devices from multiple vendors (Siemens, Festo, Turck, SensoPart, TP-Link) with unknown/unverified firmware	Article 21(2)(e) — Supply Chain Security
Visitor/external laptop (Kyan_laptop, a0:ce:c8:f7:ab:c9) on live OT subnet — no network admission controls	Article 21(2)(h) — Basic Cyber Hygiene & Training

Table 13: NIS2 Directive Violations

NIS2 Directive Violations

Security Issue Found	Standard Violated
Only one perimeter exists (edge of /18 subnet) — no segmentation between IT and OT	Defense-in-Depth — Multiple Independent Controls
No DMZ or IDMZ between MES and field layers	Defense-in-Depth — Layered Architecture
No per-PLC firewall or ACL	Defense-in-Depth — Compartmentalization
No authentication on PROFINET, S7comm, or PLC web servers	Defense-in-Depth — Authentication Layer
Single perimeter breach allows unrestricted lateral movement to all PLCs	Defense-in-Depth — No Fallback Controls

Table 14: Defense-in-Depth Violations

Defense-in-Depth Violations

Least Privilege & Zero Trust Violations

Security Issue Found	Standard Violated
MES PC (172.21.0.90) can reach every other PLC, not just the one it needs (PLC S2)	Least Privilege — Only Necessary Access
MES PC is reachable from PLCs via NTP and can poll HMIs unnecessarily	Least Privilege — Unrestricted Bidirectional Access
Engineering PCs have persistent S7comm access instead of only during programming windows	Least Privilege — Continuous Unnecessary Access
PC Cobot-ML (172.21.1.90) can reach PLCs S1, S3–S6 despite needing only OPC-UA to PLC S2	Least Privilege — Default Deny / Explicit Allow
Every device trusts every other device based on subnet membership, not verified identity or role	Zero Trust — No Implicit Trust Based on Network Location

Table 15: Least Privilege & Zero Trust Violations

3.3 Network Identification

Observed Topology

The entire lab operates on a single flat subnet: **172.21.0.0/18** (broadcast 172.21.63.255, gateway 172.21.0.230). No VLANs, no firewall zones, and no routing boundaries were observed between any device classes. All hosts - from the MES PC to individual PLCs and HMIs - share the same Layer 2 broadcast domain.

OT Network

Device	IP	Type	Notes
PLC S1-S6	172.21.x.1	Siemens S7-1500 PLCs	Process controllers, each exposing HTTP/80, OPC-UA/4840, S7comm/102, PROFINET
HMI S1-S6	172.21.x.10	Siemens MTP700	Operator panels, PROFINET
Robot Arm	172.21.1.40	Universal Robots UR3e	Cobot, firmware unconfirmed
rfdiboxcobot	172.21.1.20	Turck TBEN-S2-2RFID	RFID reader, PROFINET
Sensor S3	172.21.3.50	SensoPart	Vision sensor, HTTP
ET200SP IO S2	172.21.2.100	Siemens IM155-6PN/2 HF	PROFINET IO device, FW V4.2.4
CPX Controller S2	172.21.2.60	Festo CPX	Protocol unconfirmed
CPX Controller S6	172.21.6.60	Festo CPX	PROFINET RT cyclic confirmed (UDP 1740-1743)
Power Monitor S2	172.21.2.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed
Power Monitor S6	172.21.6.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed

Table 16: OT Network Devices

IT / MES Network

Device	IP	Role	Notes
festo-mes-pc	172.21.0.90	MES / NTP Server	Polls PLC S2 alarm table every ~3 s; NTP master; OPC-UA client to PLC S2
desktop-6jd9ili	172.21.0.168 / .192	Engineering PC (dual-NIC)	SIMATIC-PC family; TIA Portal host presumed
gebruik-tt8ke80	172.21.0.165	VMware Host	Two MACs: physical NIC (60:cf:84) + VMware vNIC (00:0c:29); VM roles unknown
PC Cobot-ML	172.21.1.90	ML Inference PC	OPC-UA client to PLC S2
CPX-IOT	172.21.0.210	Unknown / MQTT?	Festo device; silent during all captures — cloud link unconfirmed

Table 17: IT / MES Network Devices

Engineering Access

At least three distinct engineering/programming channels were observed or inferred, none of which pass through any controlled access path:

- **desktop-6jd9ili** (172.21.0.168 / 172.21.0.192): Registered engineering PC with dual NICs. Presumed TIA Portal host.
- **172.21.0.156** (MAC c4:c6:e6:d4:c3:81): Unregistered device. Maintained a persistent S7comm/102 session to PLC S2 across all five captures. Consistent with TIA Portal or Step 7 in online monitoring mode. This device is not in any inventory version.
- **Kyan_laptop** (172.21.0.179, MAC a0:ce:c8:f7:ab:c9): Identified by DCP as SIMATIC-PC family. Likely a student or visitor machine admitted to the OT subnet without restriction.

External & Cloud Connections

Two devices raise concerns about external connectivity:

- **TP-Link device** (172.21.0.200): Identified via UPnP SSDP as a TP-Link access point or router (MiniUPnPd/1.8). Broadcasts on TP-Link proprietary discovery port UDP/20002. If this device has a WAN port or wireless interface bridged to the OT subnet, it represents a direct internet-facing exposure.
- **CPX-IOT** (172.21.0.210): Festo device, OUI 00:0E:F0. Produced zero traffic in all five captures. The name ‘IOT’ and the CPX product line’s known cloud connectivity features suggest it may be a cloud gateway (MQTT over internet). Its silence during captures could indicate an idle state or encrypted tunnelled traffic not visible at Layer 2.

Flat vs. Segmented Assessment

The network is entirely flat. There is no evidence of any segmentation mechanism:

- No VLANs (capture1 shows VLAN tag value 0 = untagged/priority-tagged only on the PROFINET cyclic traffic, not a segmentation VLAN)
- No routed boundaries between device classes
- No firewall between MES and PLCs
- No DMZ or IDMZ between IT and OT layers
- No 802.1X or MAC-based port security on any observed switch

From a Purdue Model / IEC 62443 zone perspective: the network presents as a single undifferentiated zone spanning Levels 0 through 3, with potential Level 4 exposure via the TP-Link device and CPX-IOT.

4 Threat and Risk Analysis

4.1 Threat Modelling

This analysis follows principles from IEC 62443, which defines a structured approach to identifying threats in Industrial Control Systems (ICS) based on zones, conduits, and system integrity requirements.

The assessment uses a simplified STRIDE model adapted for ICS environments and considers three attacker profiles: external attackers, insiders, and opportunistic student-level actors within a lab or training environment.

Industrial systems are particularly sensitive because compromise is not limited to data loss; manipulation can directly affect physical processes, safety constraints, and production continuity.

Attacker Profiles

External attacker Typically motivated by financial gain (ransomware), disruption, or opportunistic exploitation of exposed services. Often relies on phishing, misconfigured remote access, or known vulnerabilities.

Insider A user with legitimate access (operator, engineer, contractor). Capable of bypassing many perimeter controls and posing the highest risk for silent tampering.

Student / opportunistic actor Low sophistication but high physical or local access in lab environments. Often responsible for accidental misconfigurations or simple exploitation of weak segmentation.

4.2 Threat Scenarios

PLC manipulation

An attacker gains access to the engineering environment or PLC network and modifies control logic (e.g., ladder logic, function blocks, or setpoints). This may result in unsafe actuator behaviour, incorrect process thresholds, or bypassed interlocks.

External attackers typically achieve this via compromised engineering workstations or remote access abuse. Insiders can perform direct modifications with minimal detection risk.

Denial of Service (DoS)

An attacker disrupts communication between PLCs, SCADA, and HMI systems by flooding network segments, exploiting protocol weaknesses, or overwhelming control servers.

Industrial protocols such as Modbus/TCP or OPC may lack robust authentication or rate limiting, making them vulnerable to traffic-based disruption.

Unauthorized device access

A rogue device is introduced into the control network, either physically or via network misconfiguration. Once connected, it can scan, impersonate trusted nodes, or interact with PLC services.

This scenario is particularly realistic in lab environments where physical access is possible.

Malware infection via Engineering PC

The Engineering Workstation is compromised via phishing, malicious downloads, or removable media. Once infected, attackers can pivot into PLC networks, extract logic files, or deploy malicious firmware changes.

This is one of the most critical ICS attack vectors because the Engineering PC often has unrestricted access to control assets.

Data manipulation via MES / Webshop systems

Attacks targeting Manufacturing Execution Systems (MES) or web interfaces allow modification of production orders, process parameters, or scheduling data.

This can lead to incorrect production batches, financial losses, or downstream process disruption in physical systems.

4.3 Threat Table

Asset	Threat	Attacker	STRIDE Category	Impact	Example Scenario
Engineering PC	Malware infection	External / Student	Information Disclosure, Tampering	Critical	Phishing leads to PLC compromise
Engineering PC	Unauthorized access	Insider	Elevation of Privilege	Critical	Engineer account reused or misused
PLCs	Logic manipulation	External / Insider	Tampering, Elevation of Privilege	High	Modified ladder logic alters actuator behaviour
PLCs	Command injection	Student / External	Spoofing	High	Fake control commands sent via Modbus
SCADA/HMI	Session hijacking	External	Spoofing	High	Attacker impersonates operator session
Network Segments	Traffic flooding	External	Denial of Service	High	Broadcast storm disrupts PLC communication
PLC Network	Configuration exfiltration	External	Information Disclosure	High	PLC logic downloaded and analysed
MES System	Production manipulation	External / Insider	Tampering	High	Batch parameters altered remotely
SCADA/HMI	Denial of service	External	Denial of Service	Medium-High	Flooding causes operator loss of visibility
Webshop/API	Data modification	External	Tampering, Information Disclosure	Medium-High	Order data changed, affecting production
Network Switches	Rogue device connection	Student / Insider	Spoofing	Medium	Unauthorized laptop joins control VLAN

Table 18: ICS Threat Analysis Matrix (IEC 62443-based)

4.4 Risk Matrix

Threat	Likelihood	Impact (Safety / Production / Education)	Risk Score	Priority
Engineering PC malware infection	High (3)	Critical (4): full compromise of control layer, persistent attacker access	12	Critical
PLC logic manipulation	Medium (2)	Critical (4): unsafe actuator behaviour, production shutdown, learning disruption	8	High
Unauthorized engineering access (insider misuse)	Medium (2)	Critical (4): silent logic changes, safety bypass possible	8	High
SCADA/HMI denial of service	Medium (2)	High (3): loss of operator visibility, production interruption	6	Medium
Network flooding / traffic storm	Medium (2)	High (3): loss of PLC communication, system downtime	6	Medium
MES production manipulation	Medium (2)	High (3): incorrect production runs, financial + operational impact	6	Medium
PLC configuration/data exfiltration	Medium (2)	High (3): loss of intellectual property + enables future attacks	6	Medium
Rogue device in network	Medium (2)	Medium (2): reconnaissance, lateral movement	4	Medium
Webshop/API data manipulation	Medium (2)	Medium (2): incorrect orders, indirect production issues	4	Medium
PLC command spoofing	Low (1)	High (3): incorrect control actions, potential physical instability	3	Low
Session hijacking (SCADA)	Low (1)	High (3): stealth control manipulation, loss of trust in system	3	Low

Table 19: ICS Threat Risk Assessment

5 Security Requirements

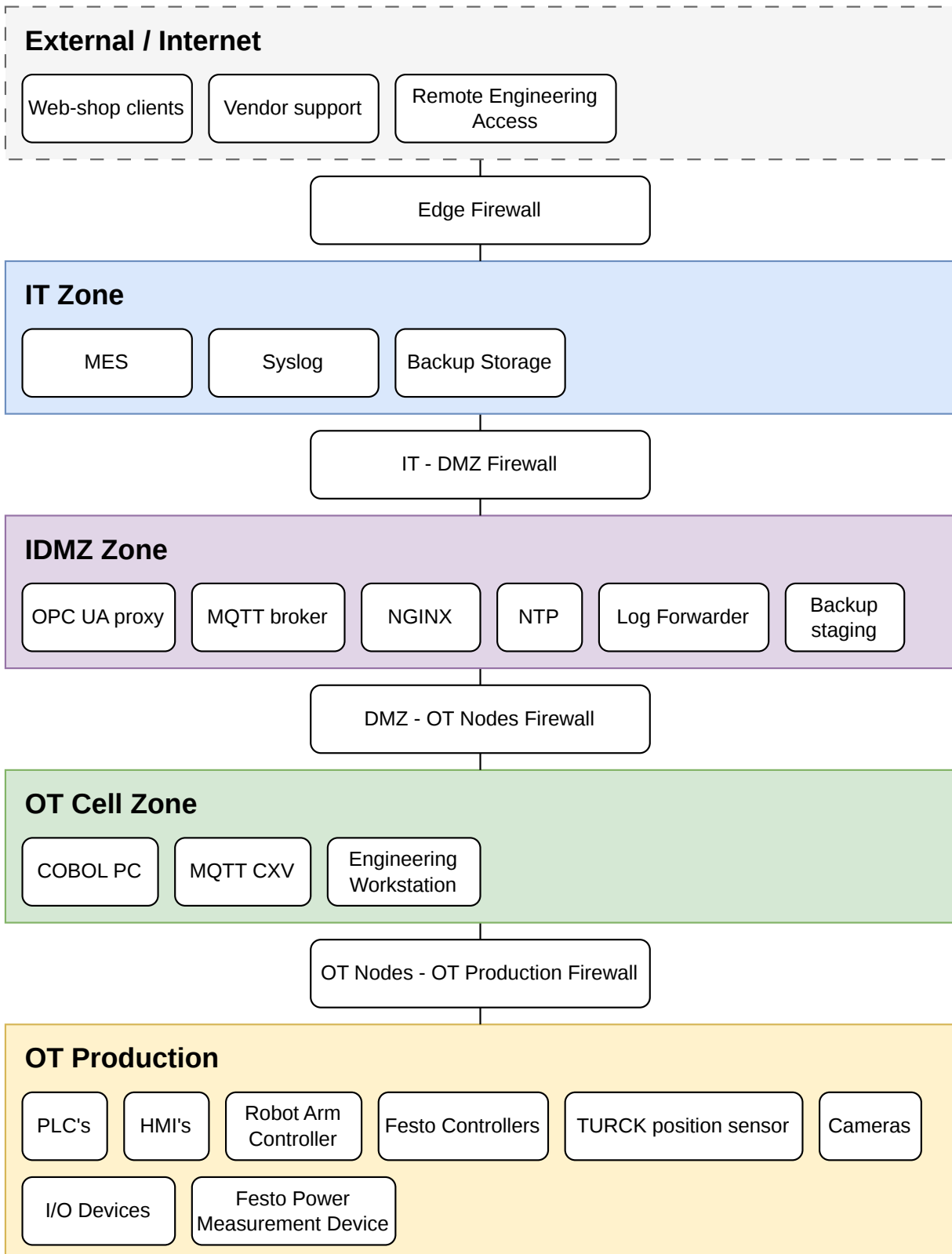
SR-01	Network Segmentation
SR-01.1	The network shall be divided into the following security zones: - OT Field Zone (PLCs, HMIs) - OT Cell Zone (MQTT Device, Cobot / ML vision PC, Engineering Workstation) - Industrial DMZ (OPC UA Proxy, MQTT Broker, Backup Server, Historian) - IT Zone (MES Server, COBOL Vision System)
SR-01.2	Each zone shall be implemented as a separate subnet/VLAN. Communication between zones shall only be permitted through firewall-controlled conduits.
SR-01.3	Direct communication from the IT Zone to the OT Field Zone shall be prohibited.
Standards Reference	- IEC 62443-3-3 SR 5.1 – Restricted Data Flow - IEC 62443-1-1 – Zone and Conduit Model - NIS2 Article 21(2)(d)
SR-02	Firewall with protocol inspection
SR-02.1	The OT zones and IT zone shall be separated with the industrial firewall(s).
SR-02.2	Firewall rules shall enforce default-deny policy on all inter-zone traffic, with only explicitly whitelisted flows permitted: - OPC UA (TCP port 4840) from IDMZ OPC UA proxy to PLC's and Festo Controllers - MQTT (TCP port 8883 TLC) from MQTT device to MQTT broker in IDMZ
Standards Reference	- IEC 62443-3-3 SR 5.2 - IEC 62443-2-1 security management
SR-03	OPC UA Hardening
SR-03.1	All OPC UA servers shall operate in Security Mode: Sign&Encrypt with SecurityPolicy:Basic256Sha256.
SR-03.2	Each client (MES, COBOL) must authenticate with an application certificate. Anonymous and username/password authentication sessions shall be disabled.
SR-03.3	OPC/UA servers shall not be reachable from the nodes inside IT zone directly, all access routes shall be set through a dedicated OPC UA proxy in IDMZ
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 1.3, SR 3.1; OPC UA Part 2 (Security Model)

SR-04	MQTT Hardening
SR-04.1	The MQTT broker shall be hosted on a dedicated server inside IDMZ. All MQTT connections shall use TLS 1.2 or higher.
SR-04.2	Each MQTT publisher (MQTT CXV device) shall authenticate with a client certificate.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
SR-05	HTTP/Web Service Hardening
SR-04.1	All HTTP services on PLC's HMI's, Festo Controllers, and cameras shall be disabled unless strictly required for an operational functionality.
SR-04.2	If the Web Interface is required, it must be migrated to HTTPS (TLS 1.2+) with a device certificate, and access restricted by firewall to only specific source IP's of pooling systems.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)
SR-06	Authentication and Least Privilege
SR-06.1	All interactive access (PLC programming, HMI configuration, robot controller configuration) to the OT devices shall require individual user authentication.
SR-06.2	Role separation shall be enforced: - Operator (monitor only) - Engineer (upload programs, change parameters) - Administrator (device configuration, user management)
SR-06.3	PLC Programming access (TIA Portal) shall be only possible from designated Engineering Workstation.
Standards Reference	- IEC 62443-3-3 SR 1.1–1.3; - IEC 62443-2-1 §4.3.3; - ISO/IEC 27001 A.9

<i>SR-07</i>	Secure Engineering Access
<i>SR-07.1</i>	A dedicated Engineering Workstation shall be physically or logically isolated from the IT Zone.
<i>SR-07.2</i>	The Engineering Workstation shall connect to PLC's only through industrial firewall via controlled conduit, with firewall rules permitting only TIA Portal protocols to the PLC's IP's.
<i>SR-08</i>	Logging and Monitoring
<i>SR-08.1</i>	All network devices (managed switches, routers, industrial firewalls, PLC's with switch modules) shall send logs to a centralized Syslog collector.
<i>SR-08.2</i>	The industrial firewalls shall log all denied traffic.
<i>SR-08.3</i>	OPC UA server shall log all sessions establishment and authentication failiures.
<i>SR-08.4</i>	The MQTT brocker shall log all connect/disconnect events and authentication failiures.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 6.1, SR 6.2; - NIS2 Article 21(2)(f); - ISO/IEC 27001 A.12.4
<i>SR-09</i>	NTP/Time synchronization
<i>SR-09.1</i>	A single NTP server must be designated. All OT devices shall synchronize using this server.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Article 21(2)(c)
<i>SR-10</i>	NTP/Time synchronization
<i>SR-10.1</i>	All PLC programs, HMI and Controllers configurations must be backed up after every change to and dedicated backup storage.
<i>SR-10.2</i>	Backup must be stored offline.
<i>SR-10.3</i>	Recovery procedure shall be documented and tested at least once per half a year.
<i>SR-10.4</i>	MES database shall be backed up once a day.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; - ISO/IEC 27001 A.12.3; - NIS2 Article 21(2)(c)

6 To-Be Architecture

6.1 Logical Network Redesign



The current flat /18 network is replaced with a layered zone architecture based on the IEC 62443 zone and conduit model. Each zone groups devices with similar operational functions. All inter-zone traffic passes through a firewall and is restricted to explicitly whitelisted traffic paths.

6.2 Logic Zones

IT Zone

The IT Zone contains nodes handling business logic and order management. It have no direct routed path to any OT device - all IT to OT traffic goes through the IDMZ.

IDMZ

The IDMZ acts as a buffer between IT and OT devices. No connection is allowed to pass from the IT to OT and vice versa. Every traffic exchange terminates inside IDMZ, and its re-initiated to the other side. This solution implements IEC 62443-3-3 SR 5.1 principle.

OT Cell Zone

The OT Cell Zone Contains devices supporting production, but not being part of the physical production process. The Engineering Workstation is placed in this logical zone, however, in physical implementation, this node will be further isolated into separate VLAN.

OT Production Zone

The OT Production Zone contains devices being part of the direct physical production process. Only inbound traffic allowed in this zone are reads and writes from the proxy services, and S7comm+ from the engineering workstation.

6.3 New Nodes

OPC UA proxy

In the AS-IS architecture, MES can directly connect to the PLC's OPC UA servers over the flat network. OPC UA proxy node aggregates all PLC's OPC UA servers traffic into single endpoint inside IDMZ. The MES connects only to proxy, that is also responsible for enforcing rules on what nodes are readable and writable from the MES. Furthermore, it logs all sessions. This solution satisfies IEC 62443-3-3 SR 3.2.

Nginx

In AS-IS architecture, MES can directly access unencrypted HTTP services from the OT nodes. As stated in security requirements, all not strictly required HTTP servers of OT devices will be disabled. However, for required HTTP traffic (e.g PLC's alarm table <- MES) the Nginx node is introduced in IDMZ. MES connects to the Nginx over HTTPS TLS 1.2, terminates the connection, access the requested HTTP node server and forwards it to the MES. Nginx enforces authentication, logging all requests and block requests for services that should not be reached from IT zone.

Dedicated MQTT broker

In the AS-IS architecture MQTT CVX device publish messages over a flat network to the MES. MQTT broker node placed in IDMZ, aggregates MQTT traffic from the CVX device using TLS 1.2 encryption, and it restrict inbound traffic to publish messages only. MES is subscribes to the MQTT broker, preventing direct communication between OT node and IT node. This solution satisfies IEC 62443-3-3 SR 1.1 and SR 3.1.

Engineering Workstation

In the AS-IS architecture, TIA Portal is run on the same PC as MES service - part of IT and reachable over flat network. A dedicated Engineering Workstation is placed in the OT Cell Zone (physically on separate VLAN). This workstation purpose is to program and configure PLC's and HMI's with separation from IT nodes. Traffic is restricted only to TCP 102 on PLC's and HMI's. This enforces least-privilege and IEC 62443-2-1 §4.3.3.

Syslog

In the AS-IS architecture, there is no centralized logging system implemented. Syslog node collects all logs from the firewalls, managed switches, OPC UA and HTTP proxy, and MQTT broker. This provides post-attack analysis and satisfies IEC 62443-3-3 SR 6.1 and NIS2 Article 21(2)(f).

Backup

In AS-IS architecture, there is no documented backup procedure. The backup node receives configuration backups from the Engineering Workstation after every change and daily database backups from the MES. It is placed on separate VLAN inside IT zone, separated from inbound traffic from OT. Satisfies IEC 62443-2-1 §4.3.4 and ISO/IEC 27001 A.12.3.

Log & Backup proxy

6.4 Firewalls

This section only describes briefly the high-level purpose of the firewall nodes. Further specification on permitted conduits is described in 7.2.2.

Edge Firewall

Terminates all VPN tunnels from remote engineers and vendor support, enforces MFA before any traffic enters the IT zone, and blocks all unsolicited inbound connections from the internet. Default-deny on all inbound. Satisfies IEC 62443-2-1 §4.3.3.6 and NIS2 Article 21(2)(i).

IT - DMZ Firewall

Controls all traffic between the IT zone and the IDMZ.

DMZ - OT Cell Firewall

Controls traffic between the IDMZ and the OT cell zone.

OT Cell - OT Production Firewall

Controls traffic between the OT cell zone and the six station VLANs. OPC UA proxy connections arrive from the IDMZ side, not the cell zone side, so they do not pass this firewall. Profinet never crosses this boundary — it remains Layer 2 within each station. All other traffic denied. Satisfies IEC 62443-3-3 SR 5.1 and the least privilege principle.

6.5 Network Implementation

The Network Implementation diagram is appended to the report for better visibility.

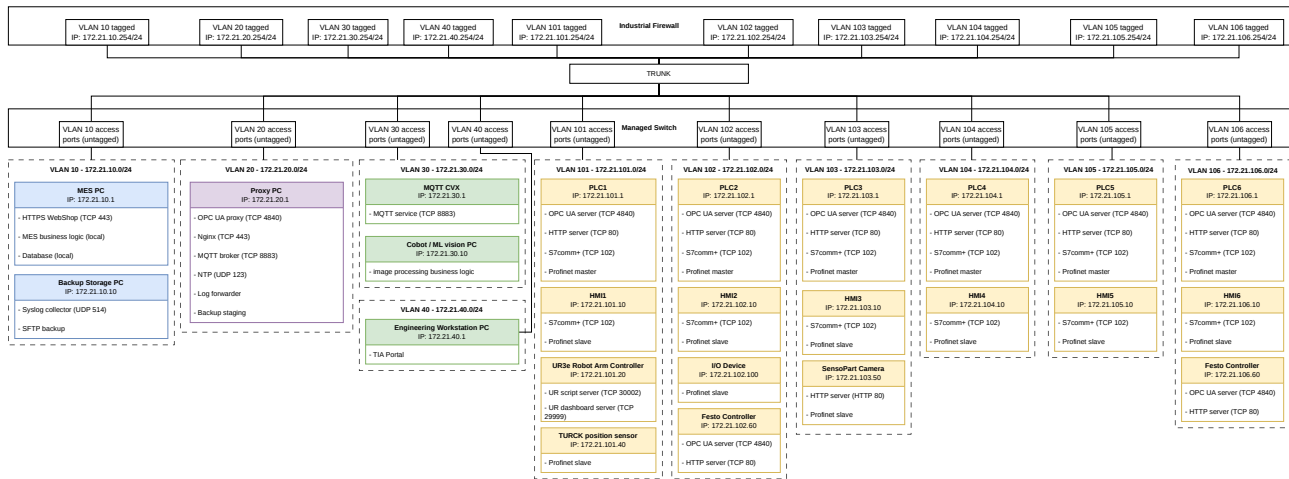


Figure 2: Network Implementation

VLAN Segmentation & Restricted Routing The redesigned factory network is implemented using VLAN-based segmentation on managed industrial switches. Each security zone is assigned a dedicated VLAN and IP subnet. Inter-VLAN communication is not performed by the switch itself but is routed through a central industrial firewall. The firewall has one tagged VLAN port for each VLAN - which is a default gateway for each node within that VLAN. The firewall enforces security policies between zones. A VLAN trunk connection between the firewall and the managed switch transports traffic for all security zones while preserving logical separation through IEEE 802.1Q VLAN tagging.

Because the switch never bridges VLANs, the only path between any two zones is through the firewall. The firewall applies a default-deny policy: traffic between VLANs is dropped unless a rule explicitly permits it. Traffic within a VLAN (for example PLC-to-HMI Profinet inside one station) is switched locally and never reaches the firewall. Profinet RT traffic is Layer 2 only and is confined to its station VLAN; it is never routed across the firewall. This realises the four logical firewall boundaries (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) on a single physical firewall, where each boundary corresponds to a rule set between the relevant VLAN interfaces. It satisfies IEC 62443-3-3 SR 5.1 (Restricted Data Flow) and SR 5.2 (Zone Boundary Protection).

VLAN	Zone	Nodes
10	IT	MES PC, Data Storage PC
20	IDMZ	Proxy PC
30	OT Cell	COBOL PC, MQTT CVX
40	OT Cell - Engineering	Engineering Workstation
101	OT Prod - Station 1	PLC1, HMI1, UR3e Robot Arm Controller, TURCK position sensor
102	OT Prod - Station 2	PLC2, HMI2, I/O device, Festo Controller
103	OT Prod - Station 3	PLC3, HMI3, SensoPart Camera
104	OT Prod - Station 4	PLC4, HMI4
105	OT Prod - Station 5	PLC5, HMI5
106	OT Prod - Station 6	PLC6, HMI6, Festo controller

Justified Protocols Routes The permitted flows exists to allow a required operational functionality - all other are denied. The IT node never reaches an OT node directly. All IT to OT connections are terminated and re-initiated in the IDMZ proxy to the other side.

Flow	Path	Protocol/Port	Justification
Process Data, MES to PLC	MES to OPC UA proxy to PLC's OPC UA server	OPC UA/TCP4840	MES reads/writes process data. MES connection is terminated in OPCUA proxy. No direct connection between MES and PLC.
Web data, MES to OT nodes	MES to Nginx to OT nodes web server	HTTPS/TCP443 (IT side), HTTP/TCP80 (OT side)	Required Web data from OT nodes is fetched by Nginx reverse proxy instead of MES directly - plain text HTTP stays in OT zone, and Nginx connects to MES through HTTPS.
Telemetry, MQTT CVX device to MES	MQTT CVX to MQTT broker to MES (subscribe)	MQTT/TCP8883 TLS	OT only publish, IT only subscribe
PLC/HMI programming	Engineering Workstation to HMI's/PLC's	S7comm+/TCP102	Programming only from the dedicated workstation in the engineering VLAN
Cobot process data	Cobot/MLvisionPC to PLC2	OPC UA/TCP4840	Vision PC needs PLC2 data only; scoped to Station 2
Time synchronization	All devices to NTP server	NTP/UDP123	Single time source for all OT devices
Logging	All devices to Syslog collector	Syslog/UDP514	Centralised log collection for monitoring
Webshop	Internet clients to MES	HTTPS/TCP443	Public webshop terminates in IT, no OT reachability

7 Hardware

7.1 Protocol Hardening

The redesign (Chapter 7) controls where each protocol may flow. This chapter defines how each protocol is secured on the device and conduit level.

Profinet

Profinet has no authentication or encryption features, so it cannot be hardened at the protocol level. Instead it is secured by isolation.

- Layer 2 only - Profinet stays inside each OT Production station (VLAN 101 - 106). It is never routed, and never crosses through firewall. Even if routing would be executed (through the attack) router would drop the communication.
- No inter-station Profinet communication - Each PLC talks Profinet (with I/O, HMI) only within own VLAN.
- DCP Set disabled - disable DCP Set through TIA Portal for devices that support this feature. This prevents rename/reconfigure attacks through DCP.

OPC UA

OPC UA is the only routed OT data protocol. Hardening is specified in SR-03. (*see Security Requirements 6.1 TODO*)

- Security mode Sign&Encrypt - Security policy Basic256Sha256. Mode 'none' is disabled on all PLC and Festo Controllers servers.
- Certificate authentication - Clients (OPC UA proxy, Cobot/MLvisionPC) authenticate with application certificates. Anonymous and username/password sessions are disabled.
- Scoped access - The Cobot/MLvisionPC can reach only PLC2 on Station 2, and no other PLC's.

MQTT

MQTT is used by the Festo CXV device for telemetry. It's hardening is specified in SR-04 (*see Security Requirements 6.1 TODO*)

- MQTT broker in IDMZ - The MQTT CXV device publishes only to a dedicated MQTT broker placed in IDMZ. IT nodes can only subscribe to the broker. No direct OT-IT MQTT path exists.
- TLS 1.2+ - TLS encryption enforced on all MQTT connections.
- Client certificates - MQTT CXV device must authenticate with certificate for publish connection to the broker. No anonymous connections allowed.
- Topic ACL's - The MQTT CXV device may publish only to its own topics. IT nodes (MES) cannot publish to the OT topics.

HTTP/Web Interfaces

Some OT devices need to expose plaintext HTTP web interfaces. Hardening is specified in SR-05 (*see Security Requirements 6.1 TODO*)

- Disabled by default - All HTTP servers are disabled unless strictly needed for operational functionality.

- Reverse proxy - Where web access is needed (e.g. MES reading the PLC alarm table), the MES connects to the Nginx reverse proxy in the IDMZ over HTTPS/TLS 1.2+. Nginx terminates the connection, fetches the OT-side resource, and returns it. Plaintext HTTP stays inside the OT zone.
- Access restriction - Nginx authenticates requests, logs them and blocks any OT server that should not be reached from IT zone. Firewall rules restrict web access to the Nginx TCP/IP port only.

S7comm+ Engineering Access

S7comm+ connection is used only for programming PLC's and HMI's. Hardening is specified in SR-06 and SR-07
 TODO link to SR's

- Single source - S7comm+/TCP102 to any PLC or HMI is allowed only from the dedicated Engineering Workstation in VLAN40.
- Conduit control - Engineering Workstation S7comm+ connection initialization passes through the firewall, enforcing restriction of Engineering Station to PLC's and HMI's only.
- User Authentication - PLC's and HMI's access requires individual login/password authentication with role separation (implemented in TIA portal).

7.2 Security Hardware

This chapter lists the hardware required to implement the redesigned architecture (Chapter 7).

Industrial Firewall

Model	Fortinet FortiGate Rugged 70G
Function	Central Layer 3 firewall and inter-VLAN router. All traffic between VLANs passes through it - under default-deny policy. Can perform stateful filtering and packet inspection of industrial protocols (S7comm+, OPC UA, MQTT, HTTP/S). Implements four logical firewalls (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) as separate rule sets between VLAN interfaces.
Placement	Network core. Has one tagged VLAN interface (.254 gateway) per VLAN. Has single 802.1Q trunk to the managed switch. No VLAN is bridged on the switch, so the firewall is the only inter-VLAN path.

Managed Switch

Model	Siemens SCALANCE XC-216
Function	VLAN-aware Layer 2 switching with IEEE 802.1Q tagging. Provides per-station access ports (untagged, one VLAN each) and the trunk uplink to the firewall.
Placement	Replace the existing unmanaged SCALANCE XB008 switches at each station. Interconnected by 802.1Q trunks; one trunk reaches the firewall.

Engineering Station

Model	Siemens SIMATIC IPC627E
Function	Dedicated managed station running TIA Portal for PLC and HMI programming/configuration. Only host permitted S7comm+ to PLCs/HMIs.
Placement	OT Cell zone, isolated in its own VLAN (40). Reaches OT Production only through the firewall on TCP 102.

IDMZ proxy server

Model	Industrial rack server or SIMATIC IPC. Hardened Linux.
Function	Hosts the IDMZ services — OPC UA proxy, Nginx reverse proxy, MQTT broker, NTP master, log forwarder, backup staging.
Placement	Placed inside IDMZ zone - on VLAN20.

Syslog & Backup Storage

Model	Standard server, Linux OS.
Function	Central Syslog collector for firewall, switches, proxies and broker; offline configuration backups (after every change) and daily MES database backups over SFTP.
Placement	IT zone, VLAN10

8 Standards and Regulatory Alignment

The security requirements in Section ?? were derived in alignment with three frameworks. **IEC 62443** provides the foundational requirement structure for industrial automation and control system (IACS) security and underlies the SR numbering used throughout this report. **ISO/IEC 27001** is applied where a requirement extends beyond purely OT-specific concerns into general information security management practice (access control, backup, logging). The **NIS2 Directive** is included to ground the requirements in the EU regulatory baseline applicable to operators of essential and important entities. Table ?? traces each security requirement back to its supporting standard or regulatory clause.

SR	Requirement	Key Controls	Standards Reference
SR-01	Network Segmentation	• Zone separation: OT Field, OT Cell, IDMZ, IT Zone • VLAN/subnet per zone • No direct IT → OT Field communication • Firewall-controlled conduits only	IEC 62443-3-3 SR 5.1; IEC 62443-1-1; NIS2 Art. 21(2)(d)
SR-02	Firewall with Protocol Inspection	• Industrial firewalls between IT and OT zones • Default-deny inter-zone policy • Allowed: OPC UA (4840), MQTT TLS (8883)	IEC 62443-3-3 SR 5.2; IEC 62443-2-1
SR-03	OPC UA Hardening	• Sign & Encrypt (Basic256Sha256) • Certificate-based authentication • Disable anonymous access • Access only via IDMZ OPC UA proxy	IEC 62443-3-3 SR 1.1, 1.3, 3.1; OPC UA Part 2
SR-04	MQTT Hardening	• TLS 1.2+ required • Client certificate authentication • Topic-level ACL enforcement • IT zone read-only access	IEC 62443-3-3 SR 1.1, 3.1; MQTT v5; NIS2 Art. 21(2)(h)
SR-05	HTTP/Web Service Hardening	• Disable unnecessary HTTP services • Enforce HTTPS (TLS 1.2+) • Device certificates required • Firewall-restricted access to specific systems	IEC 62443-3-3 SR 1.1, 3.1; NIS2 Art. 21(2)(h)
SR-06	Authentication and Least Privilege	• Individual authentication for all OT access • Role-based access control (Operator / Engineer / Admin) • Engineering access restricted to dedicated workstation	IEC 62443-3-3 SR 1.1–1.3; IEC 62443-2-1 §4.3.3; ISO/IEC 27001 A.9
SR-07	Secure Engineering Access	• Isolated engineering workstation • Firewall-controlled PLC access only • TIA Portal restricted communication	IEC 62443-3-3 SR 1.1, 5.2
SR-08	Logging and Monitoring	• Centralized syslog collection • Firewall logs all denied traffic • OPC UA authentication failure logging • MQTT connection event logging	IEC 62443-3-3 SR 6.1, 6.2; ISO/IEC 27001 A.12.4; NIS2 Art. 21(2)(f)
SR-09	Time Synchronization (NTP)	• Single authoritative NTP server • All OT devices synchronized	IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Art. 21(2)(c)
SR-10	Backup and Recovery	• Backups after configuration changes • Offline backup storage • Recovery procedure tested biannually • Daily MES database backup	IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Art. 21(2)(c)

Table 20: Security Requirements Overview

9 Discussions and Limitations

9.1 Organizational & Procedural Measures

User Roles

Three roles, enforced on PLCs, HMIs, controllers, and the robot (SR-06.2). All access uses individual accounts — no shared logins.

Role	Permissions	Typical User
Operator	Monitor HMIs, access Web Interfaces. No configuration or program changes.	Student running a session
Engineer	Upload/modify PLC programs and parameters, configure HMIs. Login through Engineering Workstation only.	Lab technician / Teacher
Administrator	Device configuration, user and certificate management, fire-wall and switch configuration.	Lab administrator

Backup Strategy

Backup Strategy is specified in SR-10 (see TODO).

- PLC programs, HMI configurations, and controller configs are backed up after every change.
- The MES database is backed up daily.
- Backups go to dedicated backup storage (VLAN 10) and a copy is kept offline.
- Recovery procedures are documented and tested at least twice per year.

Incident Response

- Detect — Anomalies surface from the Syslog collector and firewall denied-traffic logs (SR-08). Operators report unexpected station behaviour immediately.
- Contain — Isolate the affected device or VLAN (disconnect or firewall block). Stop the station if process safety is in doubt.
- Preserve — Keep logs and alarms.
- Recover — Restore PLC/HMI config or MES data from the last known-good backup (SR-10.4).
- Document — Record what happened, the cause, and the fix.

10 Conclusion

This report presented a structured analysis of the Festo factory network and its associated industrial communication environment. The assessment covered the existing inventory of operational technology assets, communication protocols, observed network traffic through packet captures, and the resulting security implications in an industrial control system context.

The inventory phase identified a heterogeneous mix of OT and IT components, including PLCs, HMIs, industrial controllers, MQTT-enabled devices, OPC UA servers, and supporting IT infrastructure such as MES systems and engineering workstations. This diversity of assets reflects a typical Industry 4.0 environment, where legacy industrial systems coexist with modern networked components, increasing both interoperability and security complexity.

Protocol analysis highlighted the use of industrial standards such as OPC UA and MQTT alongside HTTP-based services and supporting infrastructure protocols. While OPC UA provides a comparatively strong security model when properly configured, other protocols observed in the environment introduce varying levels of exposure depending on their configuration and deployment context. The network capture analysis further demonstrated how inter-zone communication patterns can lead to unnecessary exposure of OT assets if segmentation and filtering are not strictly enforced.

Based on the identified assets and traffic flows, a threat analysis was conducted to evaluate potential attack vectors, including unauthorized lateral movement between IT and OT zones, interception or manipulation of industrial messages, and abuse of weak or misconfigured services. These threats were systematically evaluated in a risk matrix, which highlighted that the highest risks are associated with insufficient network segmentation, weak authentication boundaries, and uncontrolled inter-zone communication paths.

To address these findings, a set of security requirements was defined, aligned primarily with IEC 62443, ISO/IEC 27001, and relevant sections of the NIS2 directive. These requirements formalise controls for network segmentation, firewall enforcement, secure protocol configuration, authentication and access control, logging and monitoring, time synchronisation, and backup and recovery strategies.

Finally, a proposed architecture was developed based on a zone-and-conduit model consistent with IEC 62443 principles. The design introduces clearly separated OT Field, OT Cell, Industrial DMZ, and IT zones, with strictly controlled communication paths enforced through industrial firewalls and dedicated proxy services. This segmentation significantly reduces the attack surface by ensuring that critical OT assets are not directly accessible from higher-level IT networks and that all inter-zone communication is explicitly mediated and logged.

Overall, the proposed security architecture improves the resilience, traceability, and controllability of the Festo factory network. While no industrial environment can be fully risk-free, the combination of structured segmentation, protocol hardening, and aligned security standards provides a robust baseline for mitigating the most relevant threats identified in this analysis.